

Workshop 4 in detail and the risk register in CISO Assistant

Four scenarios have been rated on a matrix and their treatment decided. Those decisions still live on the draft, which means they do not exist: a risk that is not in the register is a risk nobody will follow. This lab brings that work into the group's tool, and the entry is not mere data entry. Going back through workshop 4 in detail will reveal that the tool asks questions the draft had not asked.

Session objectives

By the end of this lab, the working group's instance contains:

- The **operational scenarios** of workshop 4, derived from the attack paths of session 6, each linked to its strategic scenario
- A **likelihood estimate** per operational scenario, justified by the supporting assets crossed and not by an overall impression
- A **risk register** where each scenario carries its current rating, its treatment option and its owner
- A **residual risk** rated for each treated scenario, consistent with the current level
- A **gap note** listing what the tool brought to light that the draft did not contain

Prerequisites

- The D5 file from session 5: framing, justified scales, baseline, business assets and supporting assets carried over from session 2, risk origin and target objective pairs.
- The strategic scenarios from session 6 and their attack paths, in particular those going through the critical third parties of the subsidiary under review (§3 and §6 of the subsidiary pack).
- The ratings and decisions from this morning's tutorial.
- Access to the working group's instance, with the study opened in session 5 and enriched in session 6. **Nothing is recreated.** If an object is missing, it is found where it was created.

What workshop 4 adds, and why it is not done in one's head

The lecture defined the operational scenario as a sequence of elementary actions carried out on supporting assets, estimated for likelihood, and session 6 set the rule linking the two workshops: to each attack path retained

in workshop 3 corresponds an operational scenario. It remains to understand why this workshop deserves an entire sequence when it seems to be nothing more than a fair copy.

The reason lies in the nature of the exercise. A strategic scenario says where the attack passes through, naming the ecosystem; it fits in one sentence and is discussed in committee. An operational scenario says how it is carried out, supporting asset by supporting asset, and that descent changes the conversation. It is while writing the sequence that the link nobody had mentioned is discovered: the service account no procedure ever revokes, the administration flow that bypasses the segmentation, the backup reachable from the same network as what it backs up. The strategic scenario is reasoned out, the operational scenario is observed.

Strategic scenario

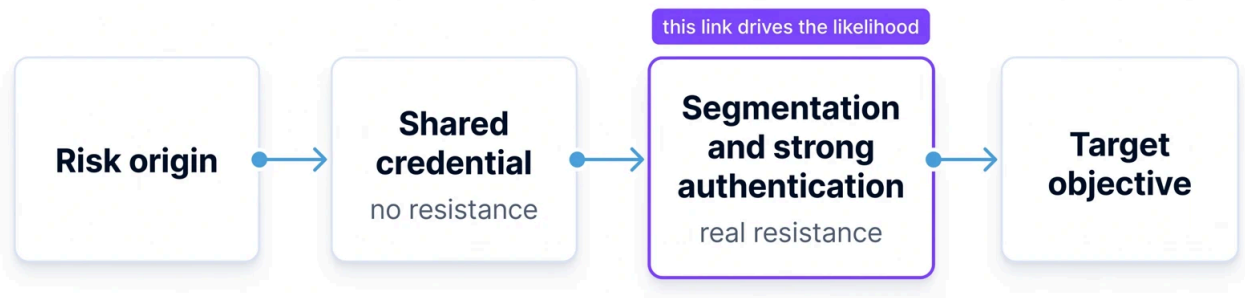
says where the attack goes through, naming the ecosystem
fits in one sentence, is debated in committee

breaks down into

Operational scenario

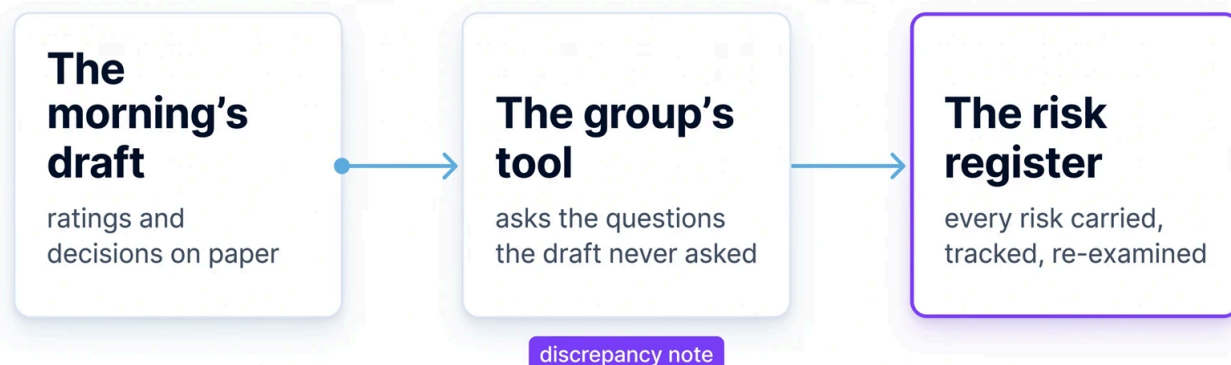
says how it is carried out, supporting asset by supporting asset
is established by writing out the chain of actions

From that difference follows the rule for rating likelihood, which is the day's difficulty. The likelihood of an operational scenario is not estimated globally, by feel; it is estimated from the path actually traveled and from what each step demands of the attacker. A step that requires only a shared identifier known to several people offers no resistance. A step that entails crossing effective segmentation, with strong authentication and logging, offers a real one. The question to ask at every link is always the same: what, here, would stop someone?



One last point of method before starting. This lab is written in objectives and validation criteria, not as a sequence of clicks. The deployed revision of the tool may differ from the one on which these objects were verified, and a screen title changes faster than a method. If a label being looked for goes by another name, look for the corresponding function and note the difference: that note is part of the deliverable.

Step 1: deriving operational scenarios from the attack paths (25 minutes)



Instructions

Derive each strategic scenario retained in session 6 into an operational scenario, saved in the tool in workshop 4 and linked to its attack path; at least the two that go through the critical stakeholders. The scenario is written as a sequence of elementary actions, know, get in, find, exploit, where each step names a supporting asset from the session 2 inventory and the action performed on it, and says what stands in its way today: a baseline measure, segmentation, authentication, logging, or nothing. A supporting asset absent from the inventory is a mapping hole to note, not an object to invent.

To produce: at least two operational scenarios saved in the tool, linked to their attack path, each step naming a supporting asset and what stands in its way; the missing supporting assets noted for the gap note.

Validation criteria

The operational scenario is complete when a colleague who does not know the file can read the sequence and say where action would be needed. If they cannot, it is because supporting assets are missing or the steps are phrased as intentions rather than actions.

✓ Step 2: estimating likelihood, link by link (20 minutes)

Instructions

Estimate the likelihood of each operational scenario, from V1 to V4, with the D5 scale as it stands, and enter it in the tool with its justification. Likelihood is read on the path actually taken: the step that offers the most resistance governs the rating of the whole. The justification names its supports, a deviation from the session 4 audit, an observed practice, the maturity and trust rated in workshop 3 for the stakeholder crossed, a public incident with a comparable *modus operandi*; not an impression, and not the severity of what would happen. For the scenario already rated in the tutorial, check that the displayed level matches the matrix.

To produce: one likelihood per operational scenario, entered in the tool, with a justification that cites at least one verifiable signal and the rating of the stakeholder crossed.

The trap in this step

The temptation will be to rate by looking at the outcome, that is, to start from the severity of what would happen. Resist it: the two axes have been kept separate since this morning for precisely this reason. A scenario that is catastrophic and very hard to carry out exists, and it is rated as such.

Validation criteria

Each likelihood refers to a named level of the scale and cites at least one verifiable signal. A justification containing only adjectives is not a justification.

✓ Step 3: building the risk register (25 minutes)

Instructions

Generate the risk assessment from the study, workshop 5, activity 1: this is the register of the scope, created only once, with one risk scenario per operational scenario, to which the tool adds the feared events without a scenario, to be rated in turn against the baseline observed in session 4. For each scenario, settle the treatment option among the tool's statuses; a scenario left open at the end of the session carries at least the written explanation

of its deferral and the name of who will decide. Each reduction carries its applied controls, their owner taken from the map of power in the subsidiary pack (§3) and their deadline; each acceptance, its justification, its re-examination deadline and the body that will sign it. The tool's quality check turned green is part of the deliverable.

To produce: the register generated and complete, all scenarios rated, each with its decision or the justification of its deferral, the reductions with controls, owner and deadline, the acceptances with justification, re-examination and body.

Validation criteria

No scenario is left without a decision or without a justification for the absence of one. Each reduction carries an owner's name and a date. Each acceptance carries its justification and its re-examination date.

✓ Step 4: rating the residual risk (20 minutes)

Instructions

Rate the residual risk of each treated scenario, after the decision and never before, asking what the measures really change: a resistance added on the path lowers likelihood, a reduction of what would be reached lowers severity, rarely both. The tool refuses a residual higher than the current level and recalls that a scenario without an additional measure keeps the same level: those refusals are part of the method. Then confront each residual with the acceptance line: if it stays above, reinforce the treatment or prepare the derogatory acceptance request for the legitimate body; both outcomes are prepared in the next sequence.

To produce: one rated residual per treated scenario, consistent with the current level, and the list of residuals that stay above the acceptance line, with the outcome chosen for each.



What the tool's refusal teaches

A tool that refuses an entry is not a tiresome tool, it is a rule of method made impossible to bypass. That a treatment cannot worsen the risk it treats seems obvious written like this; in a spreadsheet, that inconsistency goes unnoticed for months. Whoever thinks a measure creates a new risk is right to think so and wrong about the place: that new risk is a distinct scenario, rated in its own right.

✓ Self-assessment grid

Criterion	Achieved when	Sign that it is not achieved
Continuity with session 6	Each operational scenario is linked to an existing attack path	Scenarios created from scratch in the tool
Anchoring in the mapping	Each step names a supporting asset from the inventory	Steps in generic terms, with no named object
Scales reused	The levels cited are those of D5, word for word	A reinvented scale or altered labels
Justification of likelihoods	Each rating cites a verifiable signal	Adjectives without a source
Completeness of the register	No scenario without a decision, no measure without an owner	Scenarios left in the open state without explanation
Consistency of the residual	Rated after the decision, never higher than the current level	A residual entered before the measures
Honesty of the gap note	Divergent screen labels and missing supporting assets are noted	An empty gap note when objects were missing

✓ What this lab passes on to what follows

The study now carries a complete register: operational scenarios anchored in the supporting assets, justified likelihoods, decisions with their owners, and consistent residuals. The day's final sequence draws from it the treatment plan and the D7 file, and the strategy note gains its risk treatment subsection.

Keep the gap note at hand: what the tool brought to light that the draft did not contain is often the most convincing passage of an oral defense. A candidate who shows what the method taught them is more credible than a candidate whose file seems never to have met a surprise.



Answer key for the teacher: the lab run on TRAMONTANE (GØ instance)

– cliquer pour révéler